CLOUDSHIELD TECHNOLOGIES

Access Control & Identity Management Policy

Independent GRC Portfolio Project: Simulated Organization

Document Owner	IT / Security Manager
Version	1.0
Effective Date	October 6, 2026
Review Cycle	At least annually and after material identity/access changes
Related Portfolio Risks	GRC-001: Privileged Account Offboarding; GRC-002: Privileged MFA Enforcement

Portfolio artifact: this policy is written for the fictional CloudShield Technologies environment.

Document Control

Version	Date	Author / Owner	Change Summary
1.0	Oct. 6, 2026	Elizabeth Kapusa / IT & Security	Initial policy issued for simulated CloudShield GRC assessment.

1. Purpose

This policy establishes requirements for managing identities and access to CloudShield Technologies systems and information. Its purpose is to ensure that access is authorized, appropriate to job responsibilities, protected by strong authentication, reviewed periodically, and removed promptly when no longer required.

2. Scope

This policy applies to employees, contractors, temporary personnel, service accounts, administrators, and third parties with access to CloudShield-managed systems, including Microsoft Azure, Microsoft 365, GitHub, the customer-facing application, PostgreSQL environments, and approved SaaS services.

3. Policy Principles

- Least privilege: access must be limited to the minimum permissions necessary to perform approved responsibilities.
- Need-to-know: access to sensitive information must be based on a legitimate business requirement.
- Role-based access: standard roles should be used where practical to reduce inconsistent or excessive permissions.
- Separation of duties: conflicting or high-risk privileges should be separated or subject to compensating oversight.
- Traceability: access requests, approvals, changes, reviews, and removals must leave an auditable record.

4. Roles and Responsibilities

Role	Responsibility
Human Resources	Notify IT/Security of hires, transfers, role changes, and terminations through the approved workflow with sufficient lead time for access actions.
Managers / Data Owners	Approve business access, validate least privilege, participate in periodic reviews, and promptly report unnecessary access.
IT / Identity Administration	Provision, modify, disable, and remove accounts; maintain identity records; implement authentication controls; retain access evidence.
Security	Define control requirements, monitor high-risk access, review exceptions, assess privileged access, and track remediation.
Users	Protect credentials, use approved authentication methods, avoid credential sharing, and report suspected unauthorized access.

5. Identity Lifecycle Management

5.1 Joiners: Account Provisioning

- Accounts must be created only after an approved request from the appropriate manager or system owner.
- Access must be assigned according to job role and least-privilege requirements.
- Shared user accounts are prohibited unless specifically approved for a documented technical need.
- Privileged access requires separate approval from the responsible system owner and IT/Security.

5.2 Movers: Role or Responsibility Changes

- When responsibilities change, existing access must be reviewed rather than simply adding new privileges.
- Access no longer required must be removed promptly.
- High-risk role changes should trigger a review of privileged access, application roles, groups, repositories, and cloud permissions.

5.3 Leavers: Termination and Separation

- HR must initiate the approved termination workflow as soon as a separation is confirmed.
- All interactive user access must be disabled no later than the effective termination time unless a documented legal or business exception has been approved.
- Privileged access must receive priority revocation and must not remain active after termination.
- IT must verify removal or disablement across Azure, Microsoft 365, GitHub, production systems, databases, VPN/remote access, and relevant SaaS services.
- Authentication tokens, active sessions, keys, and other credentials associated with the departing user must be revoked where technically applicable.
- Completion evidence must be retained in the offboarding ticket or equivalent system of record.

6. Authentication and MFA

- MFA is required for all eligible privileged interactive accounts and for workforce access where supported by the service.
- Privileged accounts may not be excluded from MFA solely for convenience.
- Service accounts should not be used for normal interactive administration. Where feasible, CloudShield should use workload identities, managed identities, certificates, or other non-interactive mechanisms appropriate to the platform.
- Any MFA exception must have documented business justification, compensating controls, an accountable approver, an expiration date, and periodic review.

7. Privileged Access Management

- Administrative privileges must be granted only to authorized personnel with a demonstrated business need.
- Users should use separate standard and privileged identities where practical.
- Privileged permissions must be reviewed at least quarterly.
- Dormant, unnecessary, duplicate, or orphaned privileged accounts must be disabled or removed.
- High-risk privileged authentication events should be logged and reviewed; anomalous or post-termination activity must be escalated for investigation.
- Privileged access changes and exceptions must be documented and attributable to an approver.

8. Access Reviews

CloudShield will conduct recurring access reviews using a risk-based approach.

Access Type	Minimum Review Cadence	Reviewer
Privileged / administrative access	Quarterly	IT/Security + system owner
Sensitive production application/database access	Quarterly	System/data owner
Standard workforce access	At least annually	Manager / system owner
Approved access exceptions	At least quarterly and before expiration	Security + accountable owner

9. Access Requests and Approvals

- Requests must identify the user, system, requested role/permission, business justification, requester, approver, and effective date.
- The approver must be authorized to approve access to the relevant system or data.
- Self-approval of privileged access is prohibited.
- Emergency access must be time-limited, logged, reviewed after use, and removed when the emergency ends.

10. Logging, Monitoring, and Evidence

- CloudShield must retain sufficient evidence to demonstrate account provisioning, access changes, terminations, privileged-role assignments, MFA configuration, exceptions, and periodic reviews.
- Relevant authentication and privileged-access logs must be available to support investigations and control testing.
- Evidence must be protected from unauthorized modification and retained according to applicable company retention requirements.

11. Exceptions

Exceptions must be documented before implementation whenever practical and must include the business justification, affected system/account, risk, compensating controls, accountable owner, approval, and expiration or review date. Security may require additional controls when an exception materially increases risk.

12. Enforcement

Violations may result in access restriction or removal and may be escalated to management, Human Resources, Legal, or other appropriate functions. CloudShield may take immediate action to disable access when continued access creates unacceptable security risk.

13. Review and Maintenance

The IT/Security Manager will review this policy at least annually and after material changes to CloudShield's identity architecture, regulatory obligations, business operations, or significant access-control incidents.

14. Control Linkage to Portfolio Findings

Portfolio Finding	Policy Response	Expected Outcome
GRC-001: Inadequate Privileged Account Offboarding	Immediate termination-time disablement, cross-system verification, privileged review, evidence retention, and	Reduce the likelihood that former personnel retain or use unauthorized access.

Portfolio Finding	Policy Response	Expected Outcome
	monitoring.	
GRC-002: Incomplete MFA Enforcement for Privileged Accounts	Mandatory MFA for eligible privileged interactive accounts, governed exceptions, and workload-identity guidance for service accounts.	Reduce credential-compromise risk for high-impact identities.

Appendix A: Minimum Offboarding Evidence Checklist

- HR termination record and effective termination timestamp.
- Offboarding ticket/workflow identifier and responsible administrator.
- Microsoft 365 disablement evidence.
- Azure account disablement/removal evidence and privileged-role removal.
- GitHub/repository access removal where applicable.
- Production application/database access removal where applicable.
- Session/token/key revocation evidence where applicable.
- Post-termination authentication review and documented investigation of anomalies.
- Final completion/verification sign-off.